

הנדסה חברתית ופישיוג

מודול 15 — האקינג אתי מהיסוד

◀ האדם = החוליה החלשה

◀ עקרונות ההשפעה

◀ Phishing, Spear, Vishing, Baiting

◀ OSINT, GoPhish ואתיקה

למה זה חשוב?

- ◀ ~90% מהפריצות מתחילות בפישינג
- ◀ משתמש אחד שלוחץ = עוקף את כל החומות
- ◀ PNPT מחייב רכיב הנדסה חברתית
- ◀ מנצל רגש, לא באגים

עקרונות ההשפעה (צ'לדיני)

◀ **Authority** — "המנכ"ל/IT ביקש"

◀ **Scarcity/Urgency** — "רק היום", "24 שעות"

◀ **Fear** — "זוהתה פעילות חשודה"

◀ **Social Proof** — "כולם כבר עדכנו"

סוגי מתקפות

◀ **Phishing** — מייל המוני

◀ **Spear Phishing** — ממוקד (הכי יעיל)

◀ **Whaling** — לבכיר · **Vishing** — טלפון

◀ **Pretexting** · **Baiting** · **Tailgating**

OSINT — איסוף מודיעין

theHarvester -d company.com -b all ◀

LinkedIn — עובדים, תפקידים, טכנולוגיות ◀

Google Dorking, GitHub, Maltego ◀

הבסיס לספיר-פישינג משכנע ◀

אנטומיה של מייל פישינג

- ◀ שולח מזויף/דומה + נושא דחוף
- ◀ מיתוג אמין (לוגו, חתימה)
- ◀ קריאה לפעולה (לינק/קובץ)
- ◀ דף נחיתה מזויף שגונב פרטים

סימני זיהוי

- ◀ דומיין שולח שגוי במעט
- ◀ דחיפות ואיומים
- ◀ שגיאות כתיב / תרגום מכונה
- ◀ לינק שה-URL שונה מהטקסט (רחף!)

GoPhish — קמפיין מבוקר

Sending Profile + Landing Page ◀

Email Template + Users/Groups ◀

מודד: פתיחה / לחיצה / מסירת פרטים ◀

דוח מדדים למודעות עובדים ◀

כלים נוספים

SET — Credential Harvester, Payloads ◀

evilginx2 — עוקף **MFA** (גונב session) ◀

King Phisher — חלופה ◀

מדגים ש-2FA לא כדור כסף ◀

אתיקה — קריטי כאן!

- ◀ הרשאה בכתב + Scope ברור
- ◀ אל תשפיל/תלחיץ מעבר לנדרש
- ◀ **דיווח מרוכז ללא שמות**
- ◀ מטרה: חינוך, לא ענישה

הגנה

◀ הדרכות מודעות + סימולציות

◀ MFA בכל מקום

◀ סינון מייל (SPF/DKIM/DMARC)

◀ תרבות "שאל אם לא בטוח"

סיכום מודול 15

- ◀ האדם = היעד הקל; 90% מהפריצות = פישנינג
- ◀ עקרונות: סמכות + דחיפות
- ◀ OSINT → Spear Phishing → GoPhish
- ◀ אתיקה: הרשאה, ללא שיימינג; הגנה: MFA + הדרכה
- ◀ **תרגול** → `practice.md` · **פתרונות** → `solutions.md`